Lab 5: Static Code Analysis

SRN: PES1UG24CS198

Name: Janhavi Ramakrishnan

Section: D

1. Issue Documentation Table

The following issues were identified in the original scholarship_system.py and addressed in the cleaned version. Line references are approximate because they may change with formatting.

Issue	Type	Line(s)	Description	Fix Approach
Unsafe eval() (Bandit B307)	Security	calculate_merit_score()	eval() can execute arbitrary Python expressions when given untrusted input.	Replaced eval() with AST parsing and an allowlist of arithmetic operators and variables.
Broad exception handler (Bandit B110 / Pylint)	Reliability	load_results()	A bare except can hide unexpected errors and make failures difficult to diagnose.	Catch only OSError and json.JSONDecodeError.
Mutable default argument	Bug	evaluate_applicant()	logs=[] is shared across calls and can retain entries unexpectedly.	Changed the default to None and initialize a new list inside the function.
File handling without context manager	Reliability	persist_results(), load_results()	Files were opened without a with statement and without an explicit encoding.	Used with open(..., encoding='utf-8') so files close reliably.
Unused imports	Maintainability	Module imports	Unused imports add clutter and can obscure the dependencies the script actually needs.	Removed unused imports.
Non-standard function naming	Style	printShortlist()	The function name did not follow the conventional snake_case style.	Renamed it to print_shortlist().
Comparison with True	Style	Shortlist condition	Comparing a Boolean value explicitly with True is unnecessary.	Used a direct truth-value check.
Missing blank lines / final newline	Formatting	Function boundaries / end of file	The file did not fully follow the expected formatting conventions.	Added required spacing and a final newline.
Missing docstrings	Maintainability	Module and functions	The original module and functions were not adequately documented.	Added module and function docstrings.

2. Verification Results

Tool	Before	After
Pylint	Score: 4.69/10.	Score: 10.00/10.
Bandit	Reported B307 for eval() and B110 for a broad exception handler.	No issues identified; 0 findings.
Flake8	Reported unused imports, spacing problems, a bare except, and comparison to True.	No output; no violations reported.

Program test: Running the updated script with the default formula completed successfully and displayed U001 (99.0), U003 (119.0), and U005 (90.0) in the shortlist.

3. Reflection

The supplied handout asks for reflection answers but does not provide the exact reflection questions. The points below are a concise reflection on the work performed.

Purpose of static analysis:

Static analysis examines source code without executing it to identify potential bugs, security risks, and style violations.

Contribution of the tools:

Pylint helped improve code quality and maintainability, Bandit identified risky security patterns, and Flake8 identified formatting and style violations.

Most important issue:

The use of eval() was the most significant security concern because evaluating untrusted input can allow unintended code execution. An AST-based evaluator with restricted operations was used instead.

Challenges and verification:

The main challenge was fixing issues without changing the default program behaviour. The script was run again, and all three tools were rerun to verify the changes.

Use in future projects:

I would run static analysis regularly and before committing code. These tools complement, rather than replace, program execution and testing.